

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20

TOTAL MARKS: 20

Annexure A
MOCK INTERVIEW

Code of Conduct:

*I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

Annexure A

MOCK INTERVIEW

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.
2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.
3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.
4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?
5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.
6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.
7. Evaluate the limitations of the SET protocol in current online payment systems.
8. Compare SET protocol with TLS-based payment security and justify which is more practical today.
9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.
10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.
11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.
12. Compare viruses, worms, and Trojans based on propagation method and system impact.
13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.
14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.
15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.
16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.
18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.
19. Evaluate the differences between IDS and IPS in terms of response to detected threats.
20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Concepts	25	Demonstrates thorough understanding and effectively integrates multiple concepts/technologies	Good understanding with proper integration of most concepts	Basic understanding; limited or partial integration	Poor understanding; unable to integrate concepts
Experimental Design	30	Well-planned, systematic implementation with optimal solution	Correct implementation with minor issues	Basic implementation with errors or inefficiencies	Incorrect or incomplete implementation
Use of Tools	20	Effective and advanced use of tools/technologies with proper configuration	Appropriate use of tools with correct execution	Limited or inconsistent use of tools	Incorrect or minimal use of tools
Analysis of Results	15	Insightful analysis with accurate interpretation and validation of results	Good analysis with reasonable interpretation	Basic analysis with limited insights	Poor or incorrect analysis of results
Documentation	10	Clear, well-structured documentation with diagrams, code, and results	Organized documentation with necessary details	Basic documentation with missing details	Poor or incomplete documentation

CO5 AT3 CRYPTO:

R. Deepasri (192511309)

MOCK INTERVIEW – Short, Clear Answers

1. Analyze the weaknesses of SSL and explain why TLS is more secure in modern web systems.

Answer: SSL is an older security protocol with weaknesses such as outdated encryption algorithms, weaker key exchange methods, and known vulnerabilities. TLS is its improved successor with stronger cryptographic algorithms, better authentication, and improved protection against attacks. Therefore, modern web systems use TLS instead of SSL.

2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.

Answer: The client sends a connection request, and the server responds with its digital certificate. The client verifies the certificate. Using a secure key-exchange mechanism, both sides establish a shared secret. This secret is used to create session keys for encrypted communication.

Flow:

Client Hello → Server Certificate → Certificate Verification → Key Exchange → Session Key → Secure Communication.

3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.

Answer: SSL uses older and weaker cryptographic mechanisms, while TLS supports stronger encryption and authentication methods. TLS also improves key exchange, message integrity, protocol design, and protection against known attacks. TLS 1.2 and TLS 1.3 are commonly used modern versions.

4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?

Answer: If a client fails to properly validate the server certificate, an attacker could impersonate the legitimate server. The client may unknowingly establish a secure connection with the attacker. This could allow sensitive information such as login credentials or other private data to be exposed.

5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.

Answer: A digital certificate binds a server's identity to a public key. It is issued and digitally signed by a trusted Certificate Authority (CA). During TLS, the client verifies the certificate, helping confirm that it is communicating with the intended server.

6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.

Answer: SET, or Secure Electronic Transaction, was designed specifically for secure card payments. It uses digital certificates, encryption, and digital signatures to authenticate the customer and merchant and protect payment information. It also separates payment information from order information.

7. Evaluate the limitations of the SET protocol in current online payment systems.

Answer: SET is complex to implement and requires digital certificates for participants. It can increase cost and management overhead. Because of this complexity and the development of simpler HTTPS/TLS-based payment systems, SET is rarely used today.

8. Compare SET protocol with TLS-based payment security and justify which is more practical today.

Answer: SET is specifically designed for card transactions and provides strong participant authentication, but it is complex. TLS secures the communication channel between the browser and server and is much easier to deploy. **TLS-based security is more practical today** because it is widely supported and simpler to manage.

9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.

Answer: If malware attaches itself to files and spreads when those files are executed, it is a **virus**. If it automatically spreads across networks without requiring a host file, it is a **worm**. If it disguises itself as legitimate software and depends on the user installing or running it, it is a **Trojan**.

10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.

Answer: The organization should isolate infected systems, block malicious network traffic, patch vulnerable systems, update security software, and monitor network activity. Passwords and compromised credentials should also be secured. After containment, affected systems should be cleaned and safely restored.

11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.

Answer: A Trojan can trick a user into installing malicious software disguised as a legitimate application. It may then allow unauthorized access to files or modify system

data. For example, a fake utility application could secretly allow an attacker to access confidential company documents.

12. Compare viruses, worms, and Trojans based on propagation method and system impact.

Malware Propagation		Main Impact
Virus	Attaches to files/programs	Modifies or damages files
Worm	Automatically spreads through networks	Consumes resources and spreads rapidly
Trojan	Usually requires user to install/run it	Can provide unauthorized access or steal data

13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.

Answer: A packet-filtering firewall examines packet information such as source IP, destination IP, port, and protocol. It compares these values with predefined rules and allows or blocks packets.

Limitations: It has limited understanding of application-level content, may not detect sophisticated attacks, and stateless filtering does not remember previous connections.

14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

Answer: Suppose a company wants to allow HTTPS but block unauthorized remote access. The firewall can allow TCP traffic to port **443**, block unwanted remote-access ports, and allow only approved source IP addresses where required.

Example:

IF protocol = TCP AND destination port = 443

THEN ALLOW

ELSE IF source IP is unauthorized

THEN BLOCK

ELSE

APPLY SECURITY RULES

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.

Answer: A stateless firewall examines each packet independently. A stateful firewall maintains information about active connections and understands whether packets belong to an established session. Therefore, stateful firewalls generally provide better security and more intelligent traffic filtering.

16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

Firewall Type	Main Feature
Packet Filtering	Checks packet headers
Stateful Firewall	Tracks active connections
Proxy/Application Firewall	Inspects application traffic
Next-Generation Firewall (NGFW)	Combines stateful filtering with advanced application and threat inspection

Recommendation: An **NGFW** is generally suitable for an enterprise because it provides multiple layers of traffic and application-level security.

17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.

Answer: A signature-based IDS compares network activity with known attack patterns. It is effective for detecting known attacks. An anomaly-based IDS establishes normal behavior and detects significant deviations from it, making it useful for identifying previously unknown or unusual attacks.

18. Apply IDS/IPS mechanisms to prevent a DDoS attack.

Answer: The IDS monitors traffic and identifies unusual increases or attack patterns. The IPS can automatically block or rate-limit suspicious traffic based on security rules. Network filtering, traffic monitoring, and upstream protection can also help reduce the impact of a DDoS attack.

Flow:

Traffic Monitoring → Attack Detection → Identify Suspicious Sources/Patterns → Block or Rate-Limit → Log and Alert.

19. Evaluate the differences between IDS and IPS in terms of response to detected threats.

IDS	IPS
Detects suspicious activity	Detects suspicious activity

IDS

Generates alerts

Usually operates for monitoring

Does not normally block traffic itself

IPS

Automatically takes preventive action

Usually placed inline with traffic

Can block or reject malicious traffic

Simple difference: IDS = Detect and Alert; IPS = Detect and Prevent.

20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

Answer: False positives can be reduced by tuning detection thresholds, regularly updating attack signatures, establishing accurate baselines of normal traffic, and combining signature and anomaly detection. Machine-learning models can also be trained with quality data. Continuous monitoring and periodic rule refinement improve accuracy.